Auditoría exhaustiva — Calzatura Vilchez (web)

Campo	Valor
Alcance	Aplicación `calzatura-vilchez/` (Vite + React + TS), `e2e/`, `supabase/migrations/`, `functions/`, CI en `.github/workflows/`. No incluye código fuente del servicio Python en Render ni el contenido de bases de datos en tiempo real.
Fecha	2026-05-03
Metodología	Revisión estática del repo + ejecución local de `npm run typecheck`, `npm run lint`, `npm audit`; lectura de `AdminPanel-auditoria-total.md` y dimensiones A1–A8 ya adoptadas en el proyecto.
Criterio	ISO/tesis alineado con `docs/15-modulos` y matriz CU-T07.

Salidas Office / PDF

Formato	Archivo	Regenerar
PDF	[AUDITORIA-EXHAUSTIVA-2026-05.pdf]	`python scripts/build_audit_exhaustiva_pdf.py` (`pip install reportlab`)
Word	[AUDITORIA-EXHAUSTIVA-2026-05.docx]	`python scripts/build_audit_exhaustiva_docx.py` (`pip install python-docx`)

Si el `.docx` o el `.pdf` están abiertos en Word/Adobe y el script falla al guardar, se crea una copia `*-generado.docx` (solo en el script Word, como el informe del panel).

---

1. Resumen ejecutivo (semáforo)

Área	Estado	Nota breve
TypeScript	Verde	`npm run typecheck` — sin errores (evidencia en esta auditoría).
ESLint	Verde	`npm run lint` — sin errores.
Dependencias	Ámbar	`npm audit`: **1 vulnerabilidad alta** en `xlsx` (SheetJS); sin fix disponible vía npm según reporte.
CI GitHub	Verde ★	Actualizado 2026-05-03: job `Lint + Tests + Build` (ESLint + Vitest + typecheck + build) + job paralelo `E2E Playwright` con caché de browsers. Ver §5.
Panel `/admin`	Verde documental	Informes `*-auditoria.md` en `docs/15-modulos/`; E2E admin + smoke; checklist §11 actualizado.
Migraciones Supabase	Verde operativo (post-repair)	Usuario verificó `migration list` local/remoto alineados (10 versiones).
Mantenibilidad (A6)	Ámbar	Archivos muy grandes: `AdminPredictions.tsx` ~2458 líneas, `AdminProducts.tsx` ~1623, `AdminData.tsx` ~1246 (conteo PowerShell en auditoría).

Conclusión: el proyecto está en **buen estado de entrega** para la fase de auditoría/calidad descrita en documentación interna; **no** existe certificación de "cero defectos futuros". El riesgo residual principal es **supply chain (`xlsx`)** y **deuda A6/A1/A2** ya explícita en informes de módulo. El CI ahora incluye lint y E2E Playwright (★ actualizado).

---

2. Stack y programas (inventario)

Capa	Tecnología
Frontend	Node 20, Vite 8, React 19, TypeScript, React Router 7
UI	Tailwind 4, Radix, Framer Motion, Lucide
Datos	Supabase (PostgREST + Postgres), migraciones versionadas en `supabase/migrations/`
Identidad	Firebase Auth
Pagos / medios	Stripe (cliente), Cloudinary (subidas)
Excel	`xlsx` (SheetJS) — ver sección dependencias
3D tienda	Three.js + React Three Fiber
Pruebas	Vitest + Testing Library; Playwright (Chromium)
Backend Google	Firebase Cloud Functions (`functions/`, Node 20)
Herramientas	ESLint 9, `supabase` CLI como `devDependency` + `npx supabase`

---

3. Dimensiones A1–A8 (todo el producto, no solo admin)

A1 — Seguridad y acceso

- **Firebase Auth** para sesión; **Supabase anon key** en cliente (modelo habitual); riesgo operativo documentado: **token IA** vía `VITE_AI_SERVICE_BEARER_TOKEN` cuando **no** se usa `VITE_AI_ADMIN_PROXY_URL` (`aiAdminClient.ts`).
- **Firestore:** el negocio vive en **Supabase**; datos legacy en Firestore deben considerarse obsoletos respecto al código actual.
- **Carpeta Windows:** posible typo `CAZATURA` vs `Calzatura` en ruta padre — riesgo de error humano en `cd` (usar comillas y ruta copiada del Explorador).

A2 — Integridad de datos

- **Pedidos:** transiciones libres en UI — riesgo aceptado documentado (`AdminOrders-auditoria.md`); mejora opcional con máquina de estados o RPC.
- **Ventas:** transacción insert + RPC stock no única en BD — riesgo documentado en informe de ventas.
- **Import masivo (`AdminData`):** riesgo aceptado; validación server-side / cuarentena si el negocio lo exige.

A3 — Trazabilidad (ISO)

- `logAudit` en productos, pedidos (cambio de estado admin), fabricantes, usuarios, importaciones, etc. — función central en `src/services/audit.ts` .
- **Ventas diarias:** decisión/riesgo **S-03** documentado en `AdminSales-auditoria.md` (eventos explícitos opcionales a futuro).

- `functions/` **— implementado (2026-05-03):** cobertura completa del flujo de pedidos sin duplicados: trigger `AFTER INSERT ON pedidos` captura `createOrder` ; `logAuditFn()` en `stripeWebhook` captura el cambio a "pagado". Detalle en `AdminOrders-auditoria.md` (O-03) y migración `20260503100000_audit_pedidos_trigger.sql` .
- **Triggers PostgreSQL:** solo `pedidos` tiene trigger (INSERT). El resto de entidades usa logAudit a nivel de aplicación; extensión a BD posible si el negocio lo exige.
- **Código sin ruta activa en cliente:** `updateOrderStripeSession` no tiene callers en el repo cliente (el flujo Stripe real corre en `functions/`). No es un hueco operativo.

A4 — Confiabilidad y errores

- Dashboard con pantalla de error + reintentar; toasts en flujos admin; timeouts IA en predicciones — bien cubierto en docs de módulo.

A5 — Pruebas

- **Unitarios:** `src/__tests__/*.test.ts` (familia, stock, variantes, guards, finance, import rules, etc.).
- **E2E:** 21 specs bajo `e2e/` (admin amplio, smoke tienda, carrito, campañas, perfil).
- CI ahora ejecuta ESLint y Playwright E2E en job paralelo (ver §5 ★).

A6 — Mantenibilidad

- Archivos grandes (líneas aproximadas en esta auditoría): **AdminPredictions.tsx ~2458**, **AdminProducts.tsx ~1623**, **AdminData.tsx ~1246**. Recomendación: troceo por widgets/módulos cuando haya capacidad.

A7 — Rendimiento y operación

- Ruta IA con `lazy()` ; cold start Render — documentado en predicciones.
- **Migraciones:** historial remoto reparado y alineado con local (evidencia aportada por usuario en sesión previa).

A8 — Documentación

- `docs/15-modulos/` completo para módulos admin listados en `AdminPanel-auditoria-total.md` §10.
- **Residual:** contraste/foco admin layout no automatizado; política PII organizativa.

---

4. Evidencia de calidad ejecutada en esta auditoría

Comandos ejecutados en `calzatura-vilchez` el 2026-05-03:

Comando	Resultado
`npm run typecheck`	**OK** (salida sin errores).
`npm run lint`	**OK** (salida sin errores).
`npm audit`	**1 high** en paquete `xlsx` (*Prototype Pollution*, *ReDoS*); mensaje npm: *No fix available*.

---

5. Integración continua (`.github/workflows/ci.yml`) ★ actualizado 2026-05-03

Qué corre actualmente (dos jobs en paralelo):

Job	Pasos

`Lint + Tests + Build`	`npm ci` → `npm run lint` (ESLint) → `npm test` (Vitest) → `npm run typecheck` → `npm run build` (con secretos `VITE_*`)
`E2E Playwright (Chromium)`	`npm ci` → caché de browsers (clave = versión de `@playwright/test`) → `npx playwright install --with-deps chromium` → `npm run test:e2e` (con secretos `VITE_*`); sube `playwright-report/` como artifact en fallo (7 días de retención)

`e2e/.auth/admin.json` (sesión Firebase fake, datos de prueba) está rastreado en git; todas las rutas de red de Supabase / Firebase / IA están mockeadas en los specs — ninguna llamada real sale durante E2E.

PRs desde forks: GitHub no inyecta secrets por defecto → el job E2E puede fallar al arrancar el dev server. Opciones futuras: `environment` con aprobación manual, o variables placeholder no secretas solo para dev.

Brecha residual: lint y tests de `functions/` no corren en este CI (ver §7).

---

6. Inventario E2E (`e2e/*.spec.ts`)

Total **21** archivos: admin (layout, dashboard, productos filtros/código/campaña/stock/variantes/borrado, ventas, pedidos, usuarios, fabricantes, predicciones, datos, smoke admin), más `smoke.spec.ts`, `catalog-cart.spec.ts`, `campaign-landings.spec.ts`, `profile-save.spec.ts`.

Huecos relativos (no exhaustivos): flujos Stripe checkout extremo a extremo; registro/login feliz completo en E2E; accesibilidad automatizada global (axe).

---

7. Cloud Functions (`functions/`)

- `package.json` con lint propio; **no** hay evidencia en CI del monorepo de ejecución de tests/lint de `functions/`.
- **Recomendación:** paso CI `cd functions && npm ci && npm run lint` (y tests si existen).

---

8. Supabase

- **10** migraciones versionadas en `supabase/migrations/` (incluye RPC de stock, grants a `anon`, guardas comerciales, etc.).
- **RLS:** no hay `CREATE POLICY` en los `.sql` del repo — políticas deben estar gestionadas en Dashboard o en migraciones no versionadas aquí; **verificar** en proyecto remoto coherencia con uso de anon key.

---

9. Backlog priorizado (post-auditoría)

Prioridad	Ítem
P0	Sustituir o acotar **riesgo `xlsx`**: valorar `exceljs`, import dinámico, procesamiento solo server-side, o aceptación formal del riesgo con compensación (archivos de confianza, tamaño máximo).
~~P0~~ ✅	**CI:** `npm run lint` + Playwright E2E añadidos en job paralelo (2026-05-03). Brecha residual: lint de `functions/` (ver §7).
P1	**Proxy IA** en todos los entornos de producción; retirar bearer del bundle.
P1	**Pedidos:** reglas de transición si negocio lo exige.

P2	**Refactor A6** en `AdminPredictions`, `AdminProducts`, `AdminData`.
P2	**Lighthouse/axe** accesibilidad (modo oscuro, foco).
P3	**Renombrar** carpeta padre Windows si el typo `CAZATURA` genera confusión (coordinar rutas y accesos).

---

10. Fuera de alcance de este documento

- Código del servicio **Render** (Python) no presente en este repo.
- Estado en tiempo real de datos en **producción** (solo verificable en Dashboard Supabase / backups).
- Pentest externo, revisión legal de políticas de privacidad.

---

11. Referencias cruzadas

- Vista 360° admin: 15-modulos/AdminPanel-auditoria-total.md
- Matriz pruebas: `documentacion/cuadros-excel/CU-T07-matriz-pruebas-requisitos.csv` (raíz del repo monorepo)
- Credenciales / proxy IA: operaciones-credenciales.md